

Contents

Volume 05 — System Attacks & Hardware Security (L41-L50)	2
L41: Password Cracking	2
Learning objectives	2
What this lecture teaches	3
Tools mentioned	8
Commands / syntax from the lecture	8
Key terms	8
Exam-oriented recap	9
L42: Phishing Attack	9
Learning objectives	9
What this lecture teaches	10
Tools mentioned	12
Exam-oriented recap	12
L43: Malware	13
Learning objectives	13
What this lecture teaches	13
Key terms	18
Exam-oriented recap	18
L44: Wi-Fi Hacking	18
Learning objectives	18
What this lecture teaches	19
Tools mentioned	23
Key terms	23
Exam-oriented recap	24
L45: DoS and DDoS Attack	24
Learning objectives	24
What this lecture teaches	24
Tools mentioned	29
Commands / syntax from the lecture	29
Exam-oriented recap	31
L46: Elements of Hardware Security	31
Learning objectives	31
What this lecture teaches	31
Key terms	37
Exam-oriented recap	37
L47: Side Channel Attacks — Part I	38
Learning objectives	38
What this lecture teaches	38
Key terms	45
Exam-oriented recap	46

L48: Side Channel Attacks — Part II	46
Learning objectives	46
What this lecture teaches	46
Key terms	51
Exam-oriented recap	51
L49: Physical Unclonable Function	52
Learning objectives	52
What this lecture teaches	52
Key terms	59
Exam-oriented recap	59
L50: Hardware Trojan	59
Learning objectives	59
What this lecture teaches	60
Key terms	65
Exam-oriented recap	65

Volume 05 — System Attacks & Hardware Security (L41-L50)

Course: NPTEL Ethical Hacking (106105217) · **Instructor:** Prof. Indranil Sengupta, IIT Kharagpur

Series: notes-2 (transcript-grounded) — Password cracking, phishing, malware, Wi-Fi, DoS, side channels, PUF, hardware trojans.

Study notes derived from YouTube/Digimat lecture captions. For authorized lab use and exam preparation only.

L41: Password Cracking

Transcript: [41-password-cracking.md](#)

Video: https://www.youtube.com/watch?v=J-t_K-C6B8U

Week / theme: Week 8 — Passwords, phishing, Wi-Fi, DoS, hardware security

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- In this lecturer I will discuss about password authentication and password cracking.
- In this lecture we are going to explore different authentication mechanism.
- In this session we are going to explain how computer system have evolved in the way they process your password.
- So, now we will discuss about password hashing.

What this lecture teaches

Core concepts from the lecture

In this lecturer I will discuss about password authentication and password cracking.

In this lecture we are going to explore different authentication mechanism.

An authentication mechanism are, method is a way for you to prove that you are allowed to access something.

Password have been the default method of authentication for as long as most of us have needed to prove the computer that we are allowed to access it.

However, password are not the only authentication mechanism.

There are some authentication methods are there; number one something you know.

Example of these are, your good old password, bank card pin or a safe word, when the alarm company calls your home.

These are all example of using something to know to authenticate yourself, something you have.

Continued

Examples are swipe card to access a secure area, a code send to your cell phone as part of a login process, to prove you have your cell phone or a secure id token that provides a constantly changing code, you need to enter to login access.

All are something you have that can be used to authenticate yourself.

This is where biometric security comes in.

To access our data centre, we have to put our index finger on a fingerprint scanner after swiping a card.

Unless you steal someone's index finger, you will not be able to access our data centre even if you have stolen a valid swipe card.

Other biometric system include retinal scan, the blood vessels at the back of the eye and iris scan, the coloured part of the eye.

Other attribute used for authentication, a few other attributes that you occasionally see used for authentication, somewhere you are, something you can do, something you exalt, something you know.

Our focus in this session is password.

Continued

Most of us see them as an inconvenience something you have to tolerate to be able to use a service you need access to.

In this session we are going to explain how computer system have evolved in the way they process your password.

How modern online applications do authentication and why it is important to choose a strong password.

Once you finish this session, you should have a knowledge of hashing algorithm, how password cracking works and what strong password really means.

There are different types of password are there.

In the early days of computer and mainframes password were stored in a database as plain text.

When you wanted to sign in, a gatekeeper application would ask you for your password.

It would take whatever you type in and check if it was equal to whatever it had store in the database.

Continued

And if true you were granted access.

As the internet evolved and grave malicious hackers started gaining unauthorized access to the system.

Once they were in, they would immediately download the plaintext password database and have instant access to all user password.

Developers and system administrator needed to come up with the solution to this problem and the solution they came up with was password hashing.

So, now we will discuss about password hashing.

Think of a hashing algorithm as a machine.

In one end you input any text or binary data, out, the other end you get a number that is a certain length.

Let us say 32 digits long.

Continued

The data you feed, it can be any size from a few bytes to many terabytes or larger.

No matter what data you feed in, you get a 32 digit number that uniquely represent the data.

What is amazing about hashing algorithm mechanism is that if you feed something identical in, you get the same 32 digit number.

If you feed in war and peace, you get a number.

If you copy the book and feed it exactly the same text you get, the same number.

If you change a single character in the novel, you will get a completely different number.

Hashing algorithms differ in the way they work and the most notable difference is the length of the number each one splits out; MD5 is there which is extremely popular, split about 128 binary digits, SHA 2 split are there, 256 bit.

When system administrator and developer first encounter the security problem with password data base that stored as plain text, they turn to hashing algorithms for help.

Continued

What they came up with this instead of storing your password in a database, they would just store a hash of your password.

That is the number that a hashing algorithm generates when it operates on your password.

When a user changes their password or when a user account is created, the new password is typed in for the first time the computer security application test that password and run it through a hashing algorithm and store the resulting number in a database.

The next time you try to sign in and enter your password the security system runs the password you enter to the same hashing algorithm and check if the resulting hash matches then you are allowed to access the account.

No longer a password stored in clear text in a database.

If a hacker stills the user account database, they do not automatically have all passwords.

All they have is a list of hashes.

The storing hashes of passwords instead of password themselves was a major breakthrough in information security.

Continued

The story unfortunately does not end here.

Now that hashes are commonly used to authenticate user instead of plain text password, a hacker does not immediately have a list of all passwords when they steal the user accounts data base.

However, there is a way for a hacker to steal hashes and turn them that into passwords.

The method is relatively simple.

When a hackers steal a database of hashes passwords to reverse engineer the hashes convert them back to password.

The hacker generates hashes from a dictionary of words.

He think might be the password that were used.

If any of those hashes matched with he has in the database, he has managed to reverse engineer a hash and now knows what the original password is.

Continued

For example, let us say you have stolen a password database and you have the hash of the password that mug uses.

You want to know the actual password for the mug account.

So, you take the word banana and run it through the same hashing algorithm that the password database used.

You end up with the number and if the number matches the hashes in the password database for user mug to know his password.

If it does not match, then I try pear and apple and apple pear for 3 5 and progressively more words and more complex word combinations.

So, to crack a password you need to take a very large dictionary of passwords and hashes.

Each of them, then compare those hashes to what is in the password database you store and when you get a match you know the original password.

The problem is that generating hashes of words takes time.

Continued

Each word might take a few millisecond to hash.

So, we need a very fast computer to do this.

Or alternatively you can take a very large dictionary of well known passwords, generate hashes from all the word and store the word and their hashes.

Then every time you steal a password database, you can just re use that list of word and their hashes.

You do not need to recreate the hashes every time.

All you need to do is match your list of hashes with hashes in the password database and where you get a match, you have crack the password.

Alternatively, you can also create your own password by using a programming or a predefined tool.

What you have just described is called a rainbow table.

Continued

Rainbow table are a method commonly used by hackers to crack password databases that use ordinary hashing without any additional security.

Rainbow table attack on hashes password database are very effective because they are fast.

To help protect against this, a kinds of attacks developer and system administrator came up with the technique called salting password.

So, now we will discuss about how salt works.

A rainbow table attack relies on a hacker being able to take a dictionary and precomputed hashes of the words in that dictionary and compare those hashes to the hashes in a password database.

To defeat rainbow tables the information security community invented salted hashes.

The concept is relatively simple.

When you create a new password instead of just running the password on its own through a hashing algorithm you do the following.

Continued

Generate a random little piece of text, put the text at the beginning of the password, then run the combination of the little piece of text and the password through a hashing algorithm.

Then you store the little piece of text as plain text and the resulting hash.

That little piece of text is called a salt.

When someone wants to sign in, they type their password.

The security application takes the stored piece of text or salt, puts it at the front of the password that was entered and runs it through the same hashing algorithm to get a hash.

It compares the resulting hash with the hash stored in the database and if they match you are granted access.

It important to note that the salt or little piece of text, is stored as plain text with the hash.

It is also important to note that the salt is random for each password.

Continued

In other words every password has its own special little piece of text.

This is a relatively the simple concept, but it makes cracking hashed password significantly more difficult.

So, now the question is that why salt makes cracking more difficult?

Recall the rainbow table or a dictionary of word and the hashes of those words.

In the above example we use salt the little piece of text combined with our password to generate hashes.

If a hacker wants to crack passwords he cannot use his rainbow table, because the rainbow table is just a hash of individual words.

He needs to combine those words with the stored salt to get the actual hash that is stored in the database.

That makes cracking password much harder because it means a hackers rainbow table is useless and it forces into recompute hashes for every word in his dictionary.

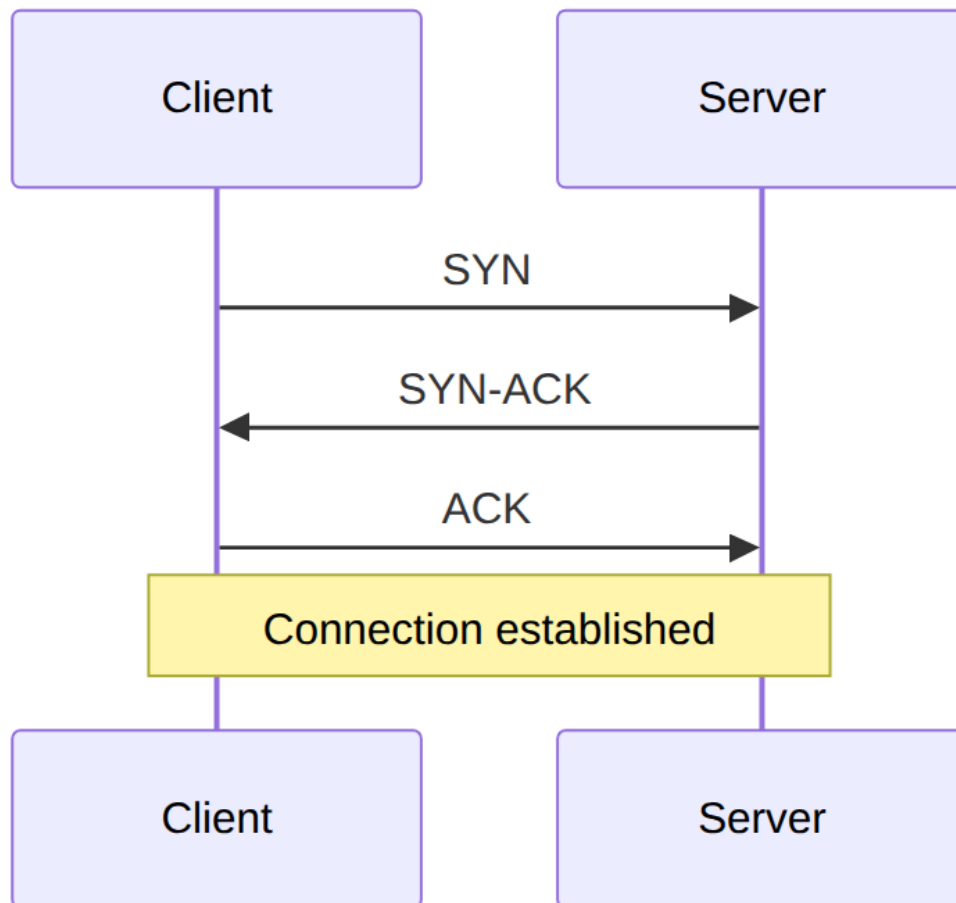


Figure 1: Architecture diagram

Tools mentioned

- Nmap

Commands / syntax from the lecture

- Nmap to find out which service is running on that particular system

Key terms

Term	Meaning in this lecture
What you have just described	a rainbow table.
That little piece of text	a salt.
That makes cracking password much harder because it	a hackers rainbow table is useless and it forces into recompute hashes for every word in his dictionary.
This	that it is important to use passwords that are very difficult to crack.

Exam-oriented recap

- This is where biometric security comes in.
- How modern online applications do authentication and why it is important to choose a strong password.
- When system administrator and developer first encounter the security problem with password data base that stored as plain text, they turn to hashing algorithms for help.
- The next time you try to sign in and enter your password the security system runs the password you enter to the same hashing algorithm and check if the resulting hash matches then you are allowed to access the account.
- The storing hashes of passwords instead of password themselves was a major breakthrough in information security.
- Rainbow table are a method commonly used by hackers to crack password databases that use ordinary hashing without any additional security.
- Rainbow table attack on hashes password database are very effective because they are fast.
- To help protect against this, a kinds of attacks developer and system administrator came up with the technique called salting password.

L42: Phishing Attack

Transcript: [42-phishing-attack.md](#)

Video: <https://www.youtube.com/watch?v=F-55CIzrey4>

Week / theme: Week 8 — Passwords, phishing, Wi-Fi, DoS, hardware security

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- This way one can hack that means, get the username and password of Gmail and Facebook.

- Spear phishing email might include references to coworker or executive at the victim's organization as well as the use of the victims name location or other personal information.

What this lecture teaches

Core concepts from the lecture

In this session, we will discuss about phishing attack, phishing is a technique by which we create a similar web page to the original one with some modification, then upload it to the hosting and access it from anywhere.

Whenever victim access this phishing website and enter sensitive and confidential information such as username, password, credit card, debit card number, network credentials and more, then it automatically goes to attacker site.

This way one can hack that means, get the username and password of Gmail and Facebook.

Now, types of phishing.

Spear phishing attacks.

Spear phishing attack are directed at specific individuals or companies, usually using information specific to the victim that has been gathered to more successfully represent the message as being authentic.

Spear phishing email might include references to coworker or executive at the victim's organization as well as the use of the victims name location or other personal information.

Whaling attacks, whaling attacks are a type of spear phishing attack that specifically target senior executives within an organization often with the objective of stealing large sums those preparing a spear phishing campaign research their victims in detail to create a more genuine message as using information relevant or specific to a target increases the chance of the attack being successful.

Continued

A typical whaling attack targets an employee with the ability to authorize payments with the phishing message appearing to be a command for an executive to authorize a large payment to a vendor, in fact the payment would be made to the attackers.

Pharming, pharming is a type of phishing that depend on DNS cache poisoning; to redirect users from a legitimate site to a fraudulent one and tricking users into using their login credential to attempt to login to the fraudulent site.

Clone phishing attack use previously delivered, but legitimate emails that contained either a link or an attachment.

Attackers make a copy or clone up the legitimate email replacing one or more link for attached file with malicious links or malware attachment.

Voice phishing, voice phishing also known as vishing.

This is basically a form of phishing that occurs over voice communications media including voice over IP, VoIP or post plain old telephone service.

A typical phishing scam uses speech synthesis software to live voicemails to notify the victim of suspicious activity in a bank or credit account and solicits the victim to respond to a malicious phone number to verify his identity.

Thus compromising the victims account credential.

Continued

Now, I am discussing about phishing technique, phishing attack depends on more than simply sending an email to victim and hoping that they click on a malicious link or open a malicious attachment, attacker use a number of technique to entrap their victims.

Java script can be used to replace a picture of a legitimate URL over browsers address bar.

The URL revealed by hovering over and embedded link can also be changed by using java script.

A variety of linked manipulation technique to treat victims into clicking on the link, link manipulation is also often referred to as URL hiding and is present in many common types of phishing and used in different ways.

Now, I will show you how to perform phishing attack using social engineering toolkit.

Now, open terminal and go to the social engineering tool by typing setoolkit.

Now, go to the option one social engineering attacks.

Then go to option 2 website attack vector.

Continued

Now, go to option 3, credential harvester attack method.

And now go to option 2, site cloner.

So, IP address for the post back in harvester or tabnabbing is 192 dot 168 dot 0 dot 101.

So, basically I am going to host my phishing page and that particular IP address which is my IP address.

Now, enter the URL to clone.

Now, I am going to put the URL www.facebook.com.

So, I am going to create a phishing page of facebook.com, ok.

So, information will be displayed to you as it arrives below.

Continued

Now, send your URL, HYPERLINK “about:blank” hosted URL to the victim machine by using some other kind of social engineering attack.

Now, victim open the phishing page.

Now, victim open the phishing page in his or her machine.

192 dot 168 dot 0 dot 101; so, it asking for the email and password, password.

Now, it will redirect to the actual login page of Facebook, and at the same time the credential already go at the attacker site.

Now, check from the attacker machine.

Now, here is all the details of the victim machine.

Wow, record the email id and password.

Continued

Here is the email id and here is the password, which the victim put at the time of login in the phishing page of Facebook.

So, this way by using the phishing attack a hacker can collect the credential like email id and password of the victim.

Tools mentioned

- **setoolkit**

Exam-oriented recap

- In this session, we will discuss about phishing attack, phishing is a technique by which we create a similar web page to the original one with some modification, then upload it to the hosting and access it from anywhere.
- Whenever victim access this phishing website and enter sensitive and confidential information such as username, password, credit card, debit card number, network credentials and more, then it automatically goes to attacker site.
- Spear phishing attack are directed at specific individuals or companies, usually using information specific to the victim that has been gathered to more successfully represent the message as being authentic.
- Clone phishing attack use previously delivered, but legitimate emails that contained either a link or an attachment.
- Attackers make a copy or clone up the legitimate email replacing one or more link for attached file with malicious links or malware attachment.
- Now, I will show you how to perform phishing attack using social engineering toolkit.
- Now, go to the option one social engineering attacks.
- Then go to option 2 website attack vector.

L43: Malware

Transcript: [43-malware.md](#)

Video: https://www.youtube.com/watch?v=d_iOT2rktJY

Week / theme: Week 8 — Passwords, phishing, Wi-Fi, DoS, hardware security

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- In this session, we will discuss about Malware.
- And we will cover the following topic, types of malware, types of virus, types of Trojan horse.
- Cyber security specialist recently discovered logic bomb that attack and destroy the hardware component in a workstation or server including the cooling fans hard drives and power supplies.

What this lecture teaches

Core concepts from the lecture

In this session, we will discuss about Malware.

And we will cover the following topic, types of malware, types of virus, types of Trojan horse.

How to secure yourself from malware?

Malware or malicious software is an umbrella term that describe any malicious program or code that is harmful to systems.

Hostile intrusive and intentionally nasty malware seeks to invade damage or disable computers.

Computer system networks tablet and mobile device often by taking partial control over device operations, like the human flu it interferes with normal function.

Malware is all about making money although; malware cannot damage the physical hardware of system or network equipment.

It can steal, encrypt or delete your data alter or hijack core computer functions and spy on your computer activity without your knowledge or permission.

Continued

Malware is a program designed to gain access to computer system normally, for the benefit of some third party without the user's permission.

Malware includes computer viruses, worms, Trojan horse, ransomware, spyware and other malicious programs.

Now, types of malware: Viruses.

Now virus is a malicious executable code attached to another executable file.

The virus spread when an infected file is passed from system to system.

Virus can be harmless or they can modify or delete data.

Opening a file can trigger a virus.

Once a program virus is active, it will infect other program on the computer.

Continued

Worms: Worms replicate themselves on the system attaching themselves to different files and looking for pathways between computers such as, computer network that shares common file storage areas.

Worms usually slowdown networks.

A virus needs a host program to run but worms can run by themselves.

After a worm affects the host, it is able to spread very quickly over the network.

Spyware, its purpose is to steal private information from a computer system for a third party.

Spyware collects information and send it to the hacker.

Trojan horse: a Trojan horse is malware that carries out malicious operations under the appearance of a desired operation, such as playing and online game.

A Trojan horse varies from a virus because that Trojan burying itself to non executable files such as image files, audio files.

Continued

Logic bombs: A logic bomb is a malicious program that uses a trigger to activate the malicious code.

The logic bomb remains non-functioning until that trigger event happens.

Once triggered, a logic bomb implements a malicious code that causes harm to a computer.

Cyber security specialist recently discovered logic bomb that attack and destroy the hardware component in a workstation or server including the cooling fans hard drives and power supplies.

The logic bomb overdrives these devices until they overheat or fail.

Ransomware: ransomware grabs the computer system or the data it contains until the victim makes a payment.

Ransomware encrypt data in the computer with the key which is unknown to the user.

The user has to pay a ransom amount to the criminal to retrieve data.

Continued

Once the amount is paid, the victim can resume using his or her system.

Back doors: A backdoor bypass the usual authentication used to access a system.

The purpose of the backdoor is to grant the cyber criminal future access to the system.

Even if the organisation fixes the original vulnerability used to attack the system.

Rootkits: A rootkit modifies the operating system to make a backdoor.

Attackers then use the backdoor to access the computer distantly.

Most rootkits take advantage of software vulnerabilities to modify system files.

Keyloggers: Keyloggers records everything the user type on his or her computer system, to obtain password and other sensitive information and send them to the source of the key logging programme.

Continued

Viruses: A virus is a fragment of code embedded in a legitimate program.

Viruses are self replicating and a design to infect other programs.

They can work havoc in a system by modifying or destroying files causing system cache and program malfunctions.

There are various types of virus are there.

File virus, this type of virus infects the system by appending itself to the end of a file.

It changes the start of a program so that the control jumps to its code.

After the execution of its code, the control returns back to the main program.

Its execution is not even noticed.

Continued

It is also called parasitic virus, because it leaves no file intact, but also leaves the host functional.

Boot sector virus: It infects the boot sector of the system executing every time system is booted.

Executing every time system is booted and before operating system is loaded, it infects other bootable media like floppy disc.

These are also known as memory virus as they do not infect file system.

Macro virus, unlike most virus which are written in low level language, these are written in high level language like visual basic.

These viruses are triggered when a program capable of executing a macro is run.

For example, macro virus can be contained in spreadsheet files.

Source code virus, it looks for source code and modifies it to include virus and to help spread it.

Continued

Polymorphic virus, a virus signature is a pattern that can identify a virus.

So, in order to avoid detection by antivirus, a polymorphic virus change each time it is installed.

The functionality of virus remain same, but its signature is changed.

Encrypted virus in order to avoid detection by antivirus.

This type of viruses exist in encrypted form.

It carries a decryption algorithm along with it so the virus first decrypts and then executes.

Stealth virus it is a very tricky virus as it changes the code that can be used to detect it.

Stealing the detection of virus becomes very difficult.

Continued

For example, it can change the read system call, such that whenever user asks to read a code modified by the virus the original form of code is shown rather than infected code.

Tunnelling virus, these viruses attempt to bypass detection by any antivirus scanner, by installing itself in the interrupt handler chain interception programs which remain in the background of an operating system and catch viruses become disabled during the course of a tunnelling virus.

Similar viruses install themselves in device drivers.

Multipartite virus, these type of virus is able to infect multiple parts of a system including boot sector, memory and files.

This makes it too difficult to detect and contain.

Armoured virus, an armoured virus is coded to make it difficult for antivirus to unravel and understand.

It uses a variety of techniques to do so.

Like, fully antivirus to believe that it lies somewhere else than its real location for using compression to complicate its code.

Continued

Trojan horse: The Trojan horse is not just a single type of virus.

It also varies to its purpose.

The cyber criminal can target a specific person or disseminates the Trojan horse of his choice everywhere.

This list will make you understand the different type of Trojan horse backdoor.

It gives malicious user remote access over the infected computer.

They can do whatever they want such as sending, receiving, launching and deleting files, displaying data and rebooting the endpoint.

Exploit, it contains data or code that abuse a vulnerability with an application software that is operating on your end point.

Rootkit, these are designed to hide certain objects or activities in your system.

Continued

This can effectively prevent malicious programs being detected.

Trojan banker, its purpose is to steal your account data for online banking system, e-payment system and credit or debit card.

Trojan DDoS, these Trojan can start up the denial-of-service attack.

Not only it can affect end points but also websites, by sending multiple request from your computer and several other infected computers.

Trojan downloader, Trojan downloader can download and install new version of malicious program onto your computer including Trojan and adware.

Trojan dropper, Trojan fake antivirus program copies the activities of antivirus software.

They are created to extort money from you in return, they will remove the detection and threat removal, even though the threat that they report are do not actually exist.

Trojan game thief if you are into gaming, you know that online gaming can also steal cash from him.

Continued

Cyber criminal also crafted this Trojan virus which steal user account information from online games.

Trojan ransom, this Trojan can change data on your end point.

This can lead to endpoint malfunction.

The cyber criminal will demand a ransom.

They will only replace your computers performance or unblock your data after you have paid them.

Trojan is SMS, Trojan SMS, this Trojan can change data on your end point.

This can lead to endpoint malfunction.

The cyber criminal will demand a ransom.



Figure 2: Architecture diagram

Key terms

Term	Meaning in this lecture
So, that	this password is needed to connect with the server, then this is the victim name and fake Error Message you can also configure your own fake Error Message.

Exam-oriented recap

- Cyber security specialist recently discovered logic bomb that attack and destroy the hardware component in a workstation or server including the cooling fans hard drives and power supplies.
- Even if the organisation fixes the original vulnerability used to attack the system.
- Attackers then use the backdoor to access the computer distantly.
- Most rootkits take advantage of software vulnerabilities to modify system files.
- For example, it can change the read system call, such that whenever user ask to read a code modified by the virus the original form of code is shown rather than infected code.
- Exploit, it contains data or code that abuse a vulnerability with an application software that is operating on your end point.
- Trojan DDoS, these Trojan can start up the denial-of-service attack.
- You can start using free branded antivirus offered in the Internet, up to date security software.

L44: Wi-Fi Hacking

Transcript: [44-wi-fi-hacking.md](#)

Video: https://www.youtube.com/watch?v=7_XzTu4pM7w

Week / theme: Week 8 — Passwords, phishing, Wi-Fi, DoS, hardware security

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- In this session, we will discuss about Wifi Hacking.
- In this session we will introduce you two common techniques used to exploit weaknesses in wireless network security implementations.

- We will also look at some of the countermeasure you can put in place to protect against such attacks.
- We will also need to be within the transmission radius of a wireless network access point.
- Now, let us look at some of the most commonly used authentication technique WEP, Wired Equivalent Privacy.

What this lecture teaches

Core concepts from the lecture

In this session, we will discuss about Wifi Hacking.

Wireless network are accessible to anyone within the router's transmission radius.

This makes them vulnerable to attacks.

Hotspots are available in public place such as Airports, Restaurant, Park, etc.

In this session we will introduce you two common techniques used to exploit weaknesses in wireless network security implementations.

We will also look at some of the countermeasure you can put in place to protect against such attacks.

A wireless network is a network that uses radio app to link computers and other devices together.

The implementation is done at the layer 1 that is in physical layer of OSI model.

Continued

Now, how to access a wireless network?

You will need a wireless network enabled devices such as a laptop, tablet, smartphone etc.

We will also need to be within the transmission radius of a wireless network access point.

Most devices will provide you with the list of available network.

If the network is not password protected, then you just have to click on connect.

If it is password protected then you will need the password to gain access.

Since, the network is easily accessible to everyone with the wireless network enabled device.

Most networks are password protected.

Continued

Now, let us look at some of the most commonly used authentication technique WEP, Wired Equivalent Privacy.

It was developed for IEEE 802.11 double standards.

Its goal was to provide the privacy equivalent to that provided by wired networks.

WEP, work by encrypting the data being transmitted over the network to keep it safe from eavesdropping.

WEP authentication, open system authentication, these methods grant access to station authentication requested based on the configured access policy.

Shared key authentication, this method sends to a an encrypted challenge to the station requesting access, the station in brief the challenge with it is key then responds.

If, the encrypted challenge matches the access point value, then access is granted.

Now, what are the weaknesses of WEP encryption?

Continued

WEP has significant design flaws and vulnerabilities.

The integrity of the packet is checked using cyclic redundancy check, CRC 32.

CRC 32 integrity check can be compromised by capturing at least 2 packets.

The bits in the encrypted stream and the checksum can be modified by the attacker so that the packet is accepted by the authentication system.

This leads to unauthorized access to the network.

WEP use the RC4 encryption algorithm to create stream cyphers.

The stream cypher input is made up of an initial value IV and a secret the length of the initial value is 24 bits long while the secrete key can either be forty bits or 104 bits long.

The total length of both the initial value and secret can either be 64 bits or 128 bits long.

Continued

The lower possible value of the secret key, make it easy to crack with initial values combinations.

We do not encrypt sufficiently, this makes them vulnerable to attack.

WEP is based on password.

This makes it vulnerable to dictionary attack.

Key management is poorly implemented.

Changing keys especially on large network is challenging.

WEP does not provide a centralized key management system.

The initial value can be reduced.

Continued

Because of this security flaw, WEP has been deprecated in favour of WPA.

WPA stands for Wi-Fi Protected Access.

It is a security protocol developed by the Wi-Fi alliance in response to the weakness found in WEP.

It is used to encrypt data on 802 dot 1 1 W length.

It uses higher initial values 48 bit instead of at 24 bits as WEP uses.

It uses temporal key to encrypt.

And, there are some weaknesses for WPA.

The collision avoidance implementation can be broken.

Continued

It is vulnerable to denial-of-service attack.

Pre shares key uses passphrase, wake passphrase are vulnerable to dictionary attack.

Now, the question is that how to crack wireless networks?

The first we will discuss about WEP cracking.

Cracking is the process of exploiting security weakness in wireless network and gaining unauthorized access.

WEP cracking refers to exploit on networks that use WEP to implement security controls.

There are basically two types of cracks namely, passive cracking.

This type of cracking has no effect on the network traffic until the WEP security has been trapped, it is difficult to detect.

Continued

Active cracking, this type of attack has an increased load effect on the network traffic.

It is easy to detect compared to passive cracking, it is more effective compared to passive cracking.

Now, there are different WEP cracking tools are there, air crack, WEP crack, qismat, web tech, crypt all these tools are available for WEP cracking.

Now, we will discuss about WPA cracking.

WPA users are 256 pre shared key or passphrase for authentications.

Short pass phrases are vulnerable to dictionary attacks and other attacks that can be used to crack passwords.

There are several tools are used for WPA cracking, cow patty, kaneabel.

There are few attacks are there for WPA shipping.

Continued

This involves intercepting packets as they are transmitted over a network.

The captured data can then be decoded using the tools such as air crack, kaneabel etc.

man-in-the-middle attack, this involves eavesdropping on a network and capturing sensitive information.

denial-of-service attack, the main intent of this attack is to deny legitimate users network resource.

Many cracking tools can be used to perform this type of attack.

It is possible to crack that WEP or WPA keys used to gain access to a wireless network.

Doing so, required software and hardware resources and patience.

The success of such attack can also depend on how active and inactive the uses of the target network are.

Continued

Now, the most important part is how to secure wireless network in minimizing wireless network attack.

An organization can attack some policies.

Number 1, changing default password that come with a hardware.

Number 2, enabling the authentication mechanism, number 3, access to the network can be restricted by following only registered mac address.

Number 4, use of strong WEP and WPA PSK keys, a combination of symbol number and characters, reduced the strength of the key in cracking using dictionary and book forced attack.

Number 5, firewall software can also help to reduce un priced access thank you.

Now, I will show you how to hack a Wi-Fi?

So, first check the interface name of the NIC card.

Continued

So, use the command ifconfig and see the interface name is wlan 0.

Now, we need to place our nic card into monitor mode to monitor all the Wi-Fi around us.

So, the command is airmon dash ng start wlan 0 here wlan 0 is the interface main.

Now, see we are already on the monitor mode and name of the monitor mode is wlan0mon and some process is also running.

So, now, we need to kill all the running processes.

So, we use the command `airmon dash ng check kill` to kill all the running processes.

So, it is killing these processes.

Now, took down all the information about the Wi-Fi around us.

Continued

We need to use the command `airodump dash ng wlan0mon`, where wlan0mon is the name of the interface.

And, now see it is successfully able to dump all the information about all the Wi-Fi around us And, this is our target Wi-Fi, NPTEL Wi-Fi.

And, see it is showing BSS ID; that means, the mac address of the router and then power.

Power represents the strength of the Wi-Fi, which value is absolute value is smaller.

It indicate the maximum power and the channel is also important.

Like our radio wireless has multiple channels so that various communications strings do not interfere with each other.

The 802.11 standard allow us for channel ranging from 1 to 14, in the US the FCC regulates wireless communication and devices for use in the states are only enable to use channel 1 through 11.

Europe use channel 1 through 13 and Japan 1 to 14, and other nations may also use the full range.

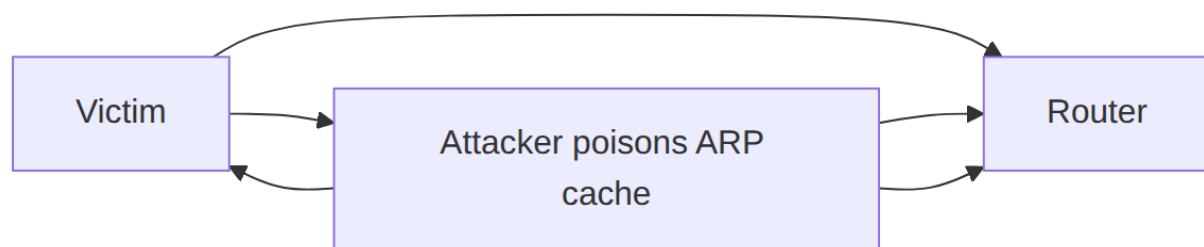


Figure 3: Architecture diagram

Tools mentioned

- Kali Linux

Key terms

Term	Meaning in this lecture
WEP cracking So, put the mac address of our target Wi-Fi	exploit on networks that use WEP to implement security controls. target router, then provide the monitor mode name which we on previously w lan 0 mon.

Exam-oriented recap

- This makes them vulnerable to attacks.
- In this session we will introduce you two common techniques used to exploit weaknesses in wireless network security implementations.
- We will also look at some of the countermeasure you can put in place to protect against such attacks.
- The bits in the encrypted stream and the checksum can be modified by the attacker so that the packet is accepted by the authentication system.
- We do not encrypt sufficiently, this makes them vulnerable to attack.
- This makes it vulnerable to dictionary attack.
- Because of this security flaw, WEP has been deprecated in favour of WPA.
- It is a security protocol developed by the Wi-Fi alliance in response to the weakness found in WEP.

L45: DoS and DDoS Attack

Transcript: [45-dos-and-ddos-attack.md](#)

Video: <https://www.youtube.com/watch?v=zXTx39PUSwI>

Week / theme: Week 8 — Passwords, phishing, Wi-Fi, DoS, hardware security

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- In this session we will discuss about DoS and DDoS attack.
- DoS is an attack used to deny legitimate user access to a resource such as accessing a website, network, email etc.
- DoS is the short form of denial-of-service.
- This type of attack is usually implemented by hitting the target resource such as a web server with too many requests at the same time.
- This result in the server failing to respond to all the request.

What this lecture teaches

Core concepts from the lecture

In this session we will discuss about DoS and DDoS attack.

DoS is an attack used to deny legitimate user access to a resource such as accessing a website, network, email etc.

or making it extremely slow.

DoS is the short form of denial-of-service.

This type of attack is usually implemented by hitting the target resource such as a web server with too many requests at the same time.

This result in the server failing to respond to all the request.

The effect of these can either be crashing the server or slowing them down.

Now, DDoS attack, a distributed denial-of-service attack is an attempt to make an online service or a website unavailable by overloading it with huge flood of traffic generated from multiple sources, unlike a denial-of-service.

Continued

A DoS attack in which one computer and one internet connection is used to flood a targeted resource with packets.

A DDoS attack use many computers and many internet connection often distributed globally in what is referred to as a botnet.

A large scale volumetric data setup and generate a traffic measured in tens of gigabits per second.

We are sure your normal network will not be able to handle such traffic.

Now, the question is that what is botnet?

Attackers build the network of hacked machines which are known as botnets by spreading malicious piece of code through emails, website and social media.

Once these computers are infected, they can be controlled remotely without their owner's knowledge and use like an army to launch an attack against any target.

A DDoS flood can be generated in multiple ways like, botnet can be used for sending more numbers of connection request than a server can handle at a time.

Continued

Attackers can have computers and effecting resource, huge amount of random data to use up the targets band width.

Due to the distributed nature of these machines, they can be used to generate distributed high traffic which may be difficult to handle.

It finally, results in a complete blockage of a service.

Now, there are different types of DDoS attack are there.

DDoS attack can be broadly categorized into 3 category, number 1: volume - based attack, number 2: protocol based attack and number 3: application layer attack.

Volume based attack include TCP flood and UDP flood, ICMP floods and other spoofed packet floods.

These are also called layer 3 and 4 attacks.

Here an attacker tries to saturate the bandwidth of the target site.

Continued

The attack magnitude is measured in bits per second.

Volume based attack, volume based attack include TCP flood, UDP flood, ICMP floods and other spoofed packet floods.

These are also called layer 3 and 4 attacks.

Here an attacker tries to saturate the bandwidth of the target site.

The attack magnitude is measured in bits per second.

UDP flood, a UDP flood is used to flood a random port on a remote host with numerous UDP packets, more specifically port number 53, specialized firewalls can be used to filter out or block malicious UDP packets.

ICMP flood, this is similar to UDP flood and used to flood a remote host with numerous ICMP echo request.

This type of attack can consume both outgoing and incoming bandwidth and a high volume up ping request will result in overall system slow down.

Continued

HTTP flood, the attacker sends HTTP get and post request to a targeted web server in a large volume which cannot be handled by the server leads to denial additional connection from legitimate clients.

Amplification attack, the attacker make a request that generate a large response which include DNS request for large PHT record and HTTP get request for large file like images, PDF or any other data file.

Next is protocol attacks; protocol attacks include SYN flood, ping of death, fragmented packet attacks, sum of DDoS etc.

This type of attack consumes actual server resources and other resources like firewall and load balancers.

The attack magnitude is measured in packets per second.

There are different types of protocol attack are there like, DNS flood.

A DNS flood are used to attack both the infrastructure and a DNS application to overwhelm a target system and consume all it is available network bandwidth.

SYN flood, the attackers send TCP connection requests faster than the targeted machine can process them, causing network situation administrator can TCP stacks to mitigate the effect of SYN floods.

Continued

To reduce the effect of SYN floods, you can reduce the timeout until a step freeze memory allocated to a connection or selectively dropping incoming connections using a firewall called IP attackers.

Ping of death, the attackers sends malformed or over sized packets using a simple ping comment.

IP allows sending 65,535 bytes packets, but sending a packet larger than 65,535 bytes violates the internet protocol and put cause memory overflow of the target system and finally, crash the system.

To avoid ping of death attacks and its variants many sides block ICMP ping message all together at their firewalls.

Next is application layer attack.

Application layer attack includes slowloris, zero- day DDoS attack.

DDoS attack that again that target apache, windows or open Phd vulnerabilities and more.

Here the goal is to crash the web server that attack magnitude is measure in request per second.

Continued

Now, different type of application layer attack are there like, application attack.

This is also called layer 7 attack where the attacker makes exclusive login database lookup or search request to overload the application.

It is really difficult to detect a layer 7 attack, because they reassemble legitimate website traffic.

Slowloris, the attacker send huge number of HTTP headers to a targeted web server, but never complete a request.

The targeted server keeps each of these false connection open and eventually overflows the maximum concurrent connection pool and leads to denial of additional connection from legitimate clients.

NTP application, the attacker exploits publicly accessible network time protocol, NTP services, to overwhelm the targeted server with user datagram protocol, UDP traffic.

Zero-day DDoS attacks, a zero-day vulnerability is a system or application flow previously unknown to the vendor and has not been fixed or test.

These are new type of attacks, coming into existence day by day.

Continued

For example, exploiting vulnerabilities for which no patch has yet been released.

Now how to fix a DDoS attack?

There are quite a few DDoS protection option which you can apply.

Depending on the type of DDoS attack, your DDoS protection start from identifying and closing all the possible operating system and application level vulnerabilities in your system, closing all the possible ports, removing unnecessary access from the system and hiding your server behind a proxy or CDN system.

If you see a low magnitude of 30 DoS, there you can find many firewall based solutions which can help you in filtering out DDoS based traffic, but if you have high volume of DDoS attack like, in gigabytes or even more.

Then should take the help of a DDoS protection service provider that offer a more holistic and proactive genuine approach.

You must be careful while approaching and selecting DDoS protection service provider.

These are number of service providers who want to take advantage of your situation.

Continued

If you inform them that you are under DDoS attack, then they will start offering you a variety of services at unreasonably high cost.

We can suggest you a simple and working solution which start with the search for a good DNS solution provider who is flexible enough, to configure, A and CNM records for your website.

Second you will need a good CDN provider that can handle peak DDoS traffic and provide you DDoS protection services as a part of their CDN package.

In this session I will show you how to perform a DoS attack using slowloris script.

Suppose our target web application is running on 192 dot 168 dot 0 dot 104 ok.

See some web application is running on that particular server 192 dot 168 dot 0 dot 104.

Now we need to check that particular server, slowloris vulnerability is present or not.

So, to find out that vulnerability, we use our best tool Nmap.

Continued

So, Nmap then I am putting the timing option T 4 and then use the script http dash slowloris dash check, then the IP address.

Let us wait for the result ok.

We got the result and it is a http slowloris check, is vulnerable.

So, can perform the slowloris attack.

So, to attack in that particular IP address, we need to use the slowloris script.

Now you can easily download slowloris script from Internet.

Now, I will show you how you can download slowloris script.

So, there is the slowloris script.

Continued

To download the script, you can copy the URL and go to terminal, use the command `git clone` and then the URL.

So, already download the script `slowloris dot pl`.

So, that is why it is showing it already exists.

So, now it is a downloaded and go to your file system and you can check `slowloris dot pl` is there.

Now, open terminal from that particular directory and perform the DDoS attack using `slowloris` script.

So, this is a perl script.

So, to run a perl script, first we need to use the command `perl`, then the script name `slowloris dot pl`, then you need to use test DNS to specify the domain name or IP address.

Now, `slowloris` script is running and it sent 494 packets successfully.

Continued

This thread now sleeping for 100 seconds.

And `slowloris` now, sent 1272 packets successfully.

So, this way it sent huge, send huge number of packets to the target tonight application.

Now check your web application is accessible or not.

Now, see this web application is not accessible.

So, this way by using the `slowloris` application successfully you can perform a DoS or DDoS attack.

Tools mentioned

- **Nmap**

Commands / syntax from the lecture

- Nmap then I am putting the timing option `T 4` and then use the script `http dash slowlo`

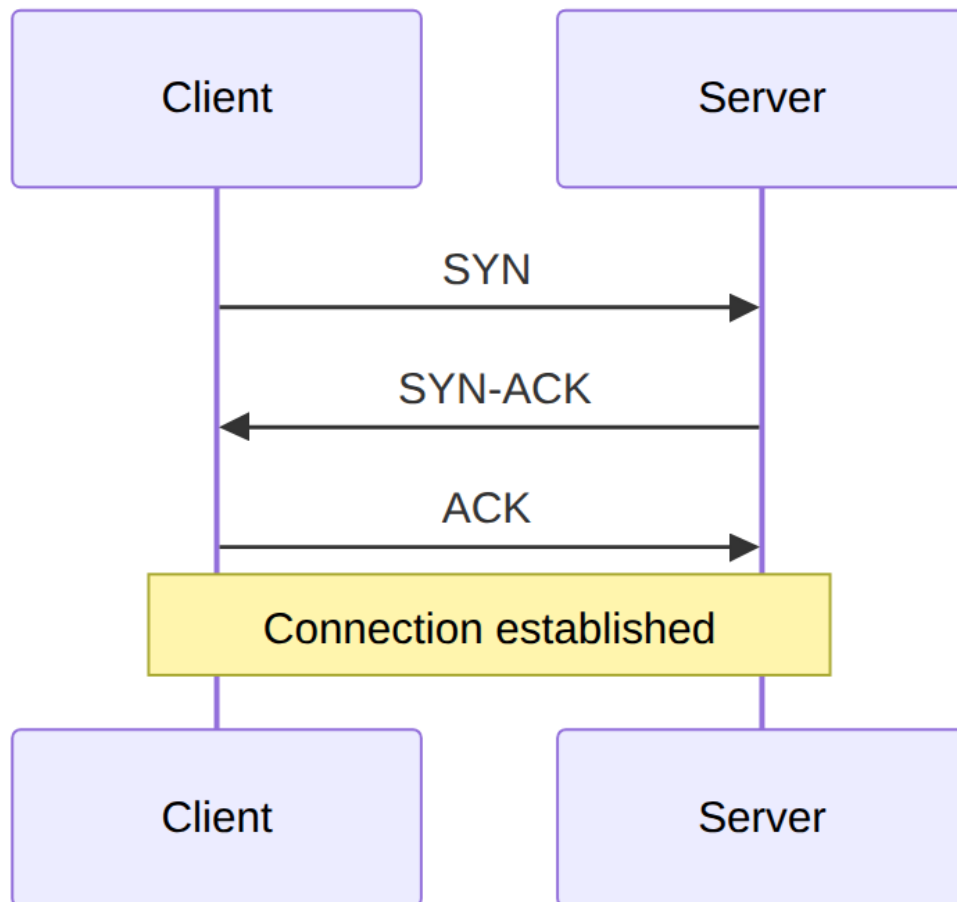


Figure 4: Architecture diagram

Exam-oriented recap

- In this session we will discuss about DoS and DDoS attack.
 - DoS is an attack used to deny legitimate user access to a resource such as accessing a website, network, email etc.
 - This type of attack is usually implemented by hitting the target resource such as a web server with too many requests at the same time.
 - Now, DDoS attack, a distributed denial-of-service attack is an attempt to make an online service or a website unavailable by overloading it with huge flood of traffic generated from multiple sources, unlike a denial-of-service.
 - A DoS attack in which one computer and one internet connection is used to flood a targeted resource with packets.
 - A DDoS attack use many computers and many internet connection often distributed globally in what is referred to as a botnet.
 - Attackers build the network of hacked machines which are known as botnets by spreading malicious piece of code through emails, website and social media.
 - Once these computers are infected, they can be controlled remotely without their owner's knowledge and use like an army to launch an attack against any target.
-

L46: Elements of Hardware Security

Transcript: [46-elements-of-hardware-security.md](#)

Video: <https://www.youtube.com/watch?v=6VmIZYN7Jlg>

Week / theme: Week 8 — Passwords, phishing, Wi-Fi, DoS, hardware security

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- In this week we shall be starting our discussion on a slightly different kind of topic which relates to hardware security.
- So, in this lectures we shall try to talk about a few things about that; so the topic of our discussion is Elements of Hardware Security, ok.
- Now, in this lecture we shall be talking about some general attacks on hardware and some of the typical counter measures that we talk about ok.
- Let us say we are breaking the device, we are breaking open, we are removing the cover or the protective layer on top, something like that; we are making a physical kind of an intrusion in the device, physical attack.

What this lecture teaches

Core concepts from the lecture

In this week we shall be starting our discussion on a slightly different kind of topic which relates to hardware security.

Now when we talk about a product, when we talk about securing a product there are actually two aspects to it.

One is of course, the software that goes into it and the conventional ways to secure things, to talk about security, to talk about breaking into a system, we actually implicitly talk about the software part of it.

But, also there is a hardware involved and there are some unconventional ways in which people can try and break into a system through the hardware backdoors.

So, in this lectures we shall try to talk about a few things about that; so the topic of our discussion is Elements of Hardware Security, ok.

Now, in this lecture we shall be talking about some general attacks on hardware and some of the typical counter measures that we talk about ok.

Now, let us see what do you mean by hardware security in the generic sense?

When you talk about hardware, well most of the time when we talk about hardware, we actually referred to computer hardware, the computer system.

Continued

Now, in a computer system what are the things that are there?

We talk about the processor, the CPUs, the different levels of software and of course the memory systems.

Broadly speaking a computer hardware involved these three things.

Firmware means some memory devices where some software are stored.

So, it is a combination of hardware and software you can say.

Nowadays we are seeing a great proliferation of mobile, handheld devices.

So, this mobile hardware is also coming in a big way in terms of their applications and applicability.

Now we all use SIM cards in our mobile phones and various kinds of device today, so you have all seen how was SIM card looks like.

Continued

A SIM card is a small micro chip where a lot of information is stored in addition to some sophisticated micro chips where also some local processing can be done.

There is something called Radio Frequency ID or RFID devices, these are the so called RFID tags; so you can attach RFID tags to various kind of devices and you can monitor you can locate those devices offline without any physical touch.

In a wireless way, you can search for those devices.

Then of course, we all use different kinds of Visa or Master Card, ATM card; these are generically called smart cards.

Now in a smart card again there is a small microchip you must have seen where there are some circuitry and also some computation capability; when you insert a card some computations can also happen locally in this microchip.

Well and we shall see later, we shall talk about this later; there is something called physical unclonable function in short PUF which can be used to secure hardware products in a very flexible way.

This is a new concept and people have been increasingly using this concept of PUF to have better security with respect to this hardware devices, ok.

So, moving on; talking about the various attacks on hardware that are possible, let us try to make a categorization.

Continued

Firstly let us talk about physical attacks where we are actually making some kind of intrusive attack on the device.

What do you mean by intrusive attack?

Let us say we are breaking the device, we are breaking open, we are removing the cover or the protective layer on top, something like that; we are making a physical kind of an intrusion in the device, physical attack.

These are typically carried out on the actual device like for example, if I have my SIM card and I want to see what is inside the SIM; I can break open my SIM, I can scratch some upper layer and so on and so forth.

And this required some sophisticated hardware instruments and tools ok.

These are not very easy to do; this is required very sophisticated tools.

There is another kind of an attack which, ok; here we are all talking about hardware based attacks; these are called planned attack.

Planned attack means suppose I am deploying or I am marketing some devices; let say I am manufacturing TV sets; I am selling them in the market.

Continued

Deliberately, I am inserting some vulnerability in my TV sets, so that I can remotely do something which the customer who is buying the TV set is not aware of.

For example, if the TV comes with the built in camera, I can switch on the camera and see what is going on in the living room whenever I want to from a remote place, ok, something like this.

These are called planned attack, because these kind of vulnerabilities are put inside the manufactured hardware well in advance in a planned way.

These are deliberately included in the hardware right.

And of course, there is another kind of an attack where you are trying to steal some data from some device where some data stored.

For example, in SIM card lots of contacts are stored; in my credit card my credit card number and other credentials may be stored and so on.

So, there are many hardware devices which can carry this kind of confidential data. And when you talk about stealing, it means how someone is taking out the data from this kind of devices.

Continued

Like when you talk about SIM card, there is something called International Mobile Subscriber Identity: IMSI.

This is a unique number; someone can steal that from my mobile number, so that someone can try to clone it; then for RFID tags also there is something called unique identification code.

Every RFID tag has a unique code associated with it; someone can steal that; someone can forge an RFID code with the same code to duplicate it.

And, again insert a smart card there can be some secret key information and other confidential information like my CVV number, my card number, etc.

All these things can be there.

So, when I am saying stealing secret data, they involve trying to take out or steal these kind of data ok.

So, here have some pictures; this is a pictorial depiction of a Trojan; something called Trojan we should be talking about.

This is a pictorial depiction of how you are securing a hardware; this is a very commonly used concept we shall be talking about.

Continued

This is called reversed engineering and this is some kind of a planned attack which we carry out on a device using some laboratory instruments, as you can see like an oscilloscope, like some other probing devices and so on ok.

These are something which we shall be talking about in some detail in the later lectures.

Now, the types of attacks that can be mounted on a hardware device; depending on the complexity first we can talk about black box testing where you do not know or we do not know anything about the internal details of the circuit or of the device.

We are not carrying out an invasive attack; we are not breaking it open.

So we have a device; we leave it as it is.

We can apply some input from outside and you can see what output it is generating; just from the input output behavior we can try to obtain some information about the device ok.

This is black box attack or black box testing.

The attackers sends an input to the circuit or device and gets the output, depending on this input/output behavior the attacker can decide what is going on inside.

Continued

What kind of algorithm is being run and if it is a cryptographic operation sometimes the attacker can also try and guess what is the secret key that is being used.

This kind of an attack is a so called non-invasive type of an attack, because we are not disturbing the device; we are not breaking or damaging the device ok.

These kind of attacks are called non-invasive attacks.

Secondly, comes physical probing where I have a device with me and I a...

Secondly, comes physical probing where I have a device with me and I am actually breaking it open in some way, so that I can probe inside and see what is happening.

Maybe I have an IC chip; I am removing the top plastic cover on the IC chip and using a very powerful microscope or using some kind of a probe, I am seeing what is there inside the chip.

This is called physical probing ok.

Here the attackers plants some kind of a probe, it depends on the sophistication of the mechanism; what kind of probe you are talking about into the chip itself and tries to read or retrieve some information that is present inside the chip ok.

Since here you are breaking open the chip; you are making some kind of a damage in the physical packaging of the chip, this is a kind of an invasive attack.

And obviously, this required very sophisticated instrumentation; if we try to break open a chip with an hammer your entire chip will get destroyed; you cannot do anything alright ok, fine.

Now, the third kind of an attack which is very sophisticated, this is called reverse engineering.

Now, for those of you who have some idea regarding how an IC chip is fabricated; you may be knowing that you start with the silicon base that is called an wafer and on a silicon wafer layer by layer we put lot of depositions.

Continued

There are various layers which are put like diffusion, polysilicon, metals, contacts.

So, it is like a building that is being constructed on top of that silicon wafer.

And, if someone using a very powerful microscope takes a picture of the chip from the top, the picture that will be getting is only about the uppermost layer, because the others layers are hidden inside right.

Reverse engineering says you take a picture from the top; you get the picture of the uppermost layer; how the layer is made; then using some kind of chemical you remove the top layer.

Then you took another picture; you get the picture of the next top layer again remove it, again take a picture you get the next layer.

So, layer by layer you are exposing the chip, you are exposing the design.

So, once you do this; someone can replicate the fabrication process and can clone a chip.

So, you can steal the design of a chip and you can make a duplicate; you can fabricate it yourself if you want.

Continued

This is called reverse engineering.

And of course, removing the layers one by one and taking photographs and getting information is an extremely sophisticated process.

And, you need very sophisticated instrumentation for this reason and you need very high resolution photography ok.

Well and a relatively new and very interesting, and of course, reverse engineering is obviously invasive because you are destroying everything layer by layer.

The last one we talk about is called side channel analysis; this is relatively new.

Side channel analysis is also non-invasive, we are not damaging the device.

We are saying that let the device operate; we are not, we are watching the device from outside.

And, we are doing some measurement; we are measuring some sensitive parameters; we shall see later what these parameters are.

Continued

These parameters can be temperature; it can be power consumption, current drawn from the power supply, electromagnetic radiation and so on and so forth.

We are trying to do some measurement; and variations in this measurements trust me we will give you lot of information about what is going on inside the chip.

Particularly for cryptographic algorithms that are running inside the chip, you can very easily break the algorithm in many cases, if the designer is not careful enough, ok.

This is what is meant by side channel attacks or side channel analysis.

Some of the typical counter measures that people have talked about or have come up with to prevent this kind of hardware based attacks; some of which I have just listed here.

The first one says obfuscate data in registers and buses.

Obfuscate means to hide them, to crypt them in some way.

Suppose I am trying to store some data; I am not storing the data just like that; I am storing it in some kind of an encrypted form so that even if someone reads it will not understand what is that ok.



Figure 5: Architecture diagram

Key terms

Term	Meaning in this lecture
Firmware	some memory devices where some software are stored.
Planned attack	suppose I am deploying or I am marketing some devices; let say I am manufacturing TV sets; I am selling them in the market.
And when you talk about stealing, it	how someone is taking out the data from this kind of devices.
This	physical probing ok.
This	reverse engineering.
The last one we talk about	side channel analysis; this is relatively new.
Obfuscate	to hide them, to crypt them in some way.
This	obfuscation.
We are using 3D stacking that	instead of a single chip we are putting chips one on top of the other.
I deliberately add some additional circuit;	I or someone else; may not be I; may be some malicious entity is adding some extra circuit to my original circuitry.
This hidden circuitry can wake up and some payload, payload	some action which will be initiated, which will be a malicious action, may be something will get deleted, something else will happen which is not intended.

Exam-oriented recap

- In this week we shall be starting our discussion on a slightly different kind of topic which relates to hardware security.

- One is of course, the software that goes into it and the conventional ways to secure things, to talk about security, to talk about breaking into a system, we actually implicitly talk about the software part of it.
 - So, in this lectures we shall try to talk about a few things about that; so the topic of our discussion is Elements of Hardware Security, ok.
 - Now, in this lecture we shall be talking about some general attacks on hardware and some of the typical counter measures that we talk about ok.
 - Now, let us see what do you mean by hardware security in the generic sense?.
 - Now in a smart card again there is a small microchip you must have seen where there are some circuitry and also some computation capability; when you insert a card some computations can also happen locally in this microchip.
 - This is a new concept and people have been increasingly using this concept of PUF to have better security with respect to this hardware devices, ok.
 - So, moving on; talking about the various attacks on hardware that are possible, let us try to make a categorization.
-

L47: Side Channel Attacks — Part I

Transcript: [47-side-channel-attacks-part-i.md](#)

Video: <https://www.youtube.com/watch?v=bmnZaZhdaIg>

Week / theme: Week 8 — Passwords, phishing, Wi-Fi, DoS, hardware security

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- So, we continue with the discussion on hardware based attacks.
- So, specifically we talked about timing analysis at times, because it is easier to understand and appreciate.
- So, let us see, what is a side channel attack?.
- See over the communication channel some communication is going on; someone has captured it and you are trying to decode it; but side channel attack is different.
- Now, I take my device to my lab; this device to my lab and in the lab I carry out some kind of experimentation on this device, so that I am trying to find out what is going on inside.

What this lecture teaches

Core concepts from the lecture

So, we continue with the discussion on hardware based attacks.

In this lecture we shall be starting our discussion on Side Channel Attacks which I told you is a new kind of an attack which is very interesting in some respect, and it is quite informative to go into a little detail about how this actually works.

So, in this lecture which is titled Side Channel Attacks Part I, here we shall be talking about firstly, the general idea what is side channel attack and then we shall be looking into a little bit detail about one kind of side channel attack that is called timing analysis attack, ok.

So, let us see, what is a side channel attack?

You see in conventional cryptography, we talk about something called cryptanalysis as the art of trying to break a code; someone has encrypted something; you are trying to break it; you are trying to decode it; but these are done entirely using software mechanism.

See over the communication channel some communication is going on; someone has captured it and you are trying to decode it; but side channel attack is different.

Here what is saying that well let us say I have a device like this; I know that something is going on inside this device; there is some encryption or decryption that is going on inside this device and somehow I have captured this device.

Now, I take my device to my lab; this device to my lab and in the lab I carry out some kind of experimentation on this device, so that I am trying to find out what is going on inside.

Continued

So, this is also a kind of cryptanalysis, but the difference is that the device where encryption decryption is going on that is in my hand; I have access to the device ok; this is the main difference.

So, this is a relatively new area of research; because traditional crypt analysis is here for many many decades and in fact, this was proposed in the mid nineties since then the importance was appreciated by the researchers and this has gained momentum.

The basic idea is like this; that you see this picture; in this diagram here we show some kind of a circuit board; some kind of a circuit board is here which is doing something and you see we here we are showing some kind of an oscilloscope, some kind of an instrument which using a probe is connected to this board.

So, while this board is carrying out some operation I am observing what is going on; I am observing some kind of wave forms in the axis of time.

So, the basic idea is something like this; we are trying to capture unintended leakage of information; this is the keyword unintended leakage of information during operation, ok.

And this information that you are capturing can be used to extract even the secret key that you are using for encryption/decryption with relatively very less effort, ok.

And understanding side channel attack is therefore very important; because unless you are aware of this, you may be building a piece of hardware which can be very easily attacked in this way and the secret key can be retrieved relatively easily.

Therefore, in future generation devices this kind of consideration has to be incorporated in a very big way and all security devices and systems must have this kind of

consideration in place, fine.

Continued

So, side channel attack is important; because the main point is the developer of a secure product; suppose, I am developing some product related to security, ok.

So, mean if I say that well my work is only to look at the software; I have to ensure that a software is secure I do not care about the hardware; that is not the right attitude, I have to ensure the security of my whole device; it includes both software as well as hardware.

So, the developer of the product has to defend the product against all possible attack paths; it can be software based, it can also be hardware based.

Then side channel attack, the point to notice that we are not saying that the cryptographic algorithms that are running inside the devices are bad or weak we are not saying that.

We are saying that they are mathematically very sound, very stable we all know that; but when you are doing a hardware implementation of this algorithm, somewhere you have become a little careless and because of that carelessness some information is getting leaked out while the algorithm is getting executed in hardware that is the main idea.

So, it is the implementation of the algorithms that is not proper and some information is getting leaked out during the execution of the algorithm in hardware, this is the basic concept, ok.

So, the typical side channels people talk about, see the side channel as I said is nothing, but some unintended leakage of information; but what do you mean by information?

In this picture we have showed some of the most common side channels or information that have been exploited by researchers; like you see timing; how much time it is required to execute an algorithm; this can be one information.

Continued

How much power is being consumed during computation of something; you observe the variation of power with time that can give you some information; electromagnetic emissions, if you have an electromagnetic sensor sitting on top of your device, so, when something is going on inside, you can directly sense the electromagnetic radiations and observe the variations that are taking place, ok.

So, this power consumption and electromagnetic emissions variations will be very similar in nature.

Heat, if you have some kind of a heat sensor, you can see how the variation of heat is taking place with time; when the chip is becoming hotter, when just becoming cooler.

Similarly, faulty outputs, some of the outputs, you can inject some fault; these are called fault analysis attacks.

You can inject some faults deliberately by changing supply voltages making some disturbance in some of the channels that way you can inject some errors and because of that some important information might come out which may be helpful for you in breaking the system.

Data coupling, well, if there are some coupled data that are going; you see some means I am just giving a simple example; suppose you are watching your TV in one of the rooms and your door and windows are everything closed.

So, you are, I means so many, you are assuming that no one is knowing what you are watching, but the video cable that is connected to a TV let us say that is going and is getting connected to an antenna which is on your roof; someone outside your house can connect some kind of a probe on that cable and can capture that data that is flowing through that cable that is what I mean by data coupling; that you can see; that is data coupling, And that data if I connect to another TV, I can see exactly what you are watching; I can replicate that; if I amplify it suitably and I plug into another TV I can see what you have been watching inside, ok.

And scan data during test, this is another thing, there are some additional signal pins that are kept in an IC chip, that are helpful for testing the chip; during testing those are required, but when you are not testing even during that time some data are being coming out of those pins.

Continued

So, if you measure those signals actually you are getting some information what is there, ok.

So, all these are typical side channels which people have explored and there are lot of research papers on these topics.

So, specifically we talked about timing analysis at times, because it is easier to understand and appreciate.

Now, this kind of an attack was first proposed by Paul Kocher in the year 1995, in the mid 90's.

So, the idea is very simple; you are trying to measure the time that is taken for some particular operation to complete.

Attacker tries to break a crypto system by analyzing the execution time.

Suppose, I somehow can tell that well it is now an encryption process is starting and here it is ending.

So, how much time it is taking; if I can find that out and if I can measure it, that time can give you some very important information, well.

Continued

Here I will give an example and in this process what does it try to exploit; what are you trying to exploit?

You see, if you look at a symmetric key algorithm; you have already briefly seen how public key cryptography algorithm works; we have seen that RSA; we have mentioned RSA is the most widely used public key algorithm that is being used today, ok.

In RSA how you do encryption decryption; basically, we are raising a number to the power of another number modulo some other number.

This a , b , n are very large numbers; this is basically how this encryption and decryption both take place.

Now if I can measure the time, we will see that we can get lot of more information about this number b , this b is actually the key, the power; either the public or private key whatever, b is the key.

So, if I can measure the time, I can get lot of information about this b and let us see how?

The basic way we compute this kind of modular exponential, a to the power $b \bmod n$; this is called modular exponentiation algorithm.

And for modular exponentiation one of the most commonly used algorithm is square and multiply; this I will explain very briefly; square and multiply is one of the most efficient, you see when you compute a to the power b , you do not multiply a to itself b minus 1 times that is very inefficient.

Continued

If b is a very large number, you need very large number of multiplications to compute a to the power b .

So, this square and multiply algorithm as you shall see, that the execution time will depend when we do a to the power b .

If you treat this b as a binary number, it will consist of a string of 0's and 1's, execution time will directly depend on number of 1's in this b ; it will be proportional to this number of 1's actually in fact.

So, here you can use repeated execution with the same key different inputs you can try out various ways; you can do various statistical correlation analysis and with multiple experimentation you can try to recover the key in a complete way; this is the basic idea, ok.

Let us try to understand how it works without going into too much mathematical detail.

This square and multiply algorithm works like this.

So, I am stating the algorithm here and I shall be explaining with the help of an example in the next slide; just remember this slide here.

Power x , n means I am trying to compute x to the power n .

Continued

So, I am writing it like this; power as a function of x and n .

If n equal to 1 the result is x , obviously; if n is even suppose if n is let us say 10, if n is 10 then I say that x to the power 10 is the same as x square to the power 5, right.

So, x square to the power n by 2, right; similarly, if I have x to the power 9, I am saying it is same as x multiplied by x square to the power 4.

So, if x is odd if not x ; say if a n is odd then it will be x multiplied by x square to the power n minus 1 by 2 which is 4, 9 minus 1 by 2.

So, if you repeatedly apply this formula then the number of operations can be drastically reduced.

You see here we are carrying out only two kinds of operation; one is squaring, other is multiplication; we are being squaring here or here and multiplication we are doing here, ok.

So, if you are not using this efficient method and if you are calculating x to the power n , then we need n minus 1 multiplications; but, if we use this technique then the number gets drastically reduced to approximately of the order of $\log n$ multiplication, $\log n$ to the base 2.

So, it becomes much faster, ok.

Continued

Let us work out a simple example; x to the power 13, 13 in binary is 1101.

You see these, each of these will indicate the different powers of x ; this least significant bit means x to the power 1; this 0 will be x to the power 2; this 1 is x to the power 4; this 1 is x to the power 8.

Now because there is a 0 here; there is a 0 out here, that is why this x to the power 2, x square is missing is not there.

So, depending on how many 1's are there, that many terms will be there in the final product so many multiplication operations will be carried out.

So, for 13 if you just work out that previous algorithm the previous steps, step by step powered x 13, x to the power 13 is nothing, but x multiplied by x square to the power n minus 1 by 2 13 minus 1 by 2 is 6.

So, in the first step we write, it is x multiplied by x square to the power 6.

This x square to the power 6 we write again as since now in the 6 is even x square whole square.

So, this we write as x into x square whole square to the power 3 which means x to the power 4 to the power 3, like this you proceed.

Continued

This 3 is now again odd so, this will be x to the power 4 whatever is this first one multiplied 1, 3 minus 1 by 2; this square 1 and finally, this is 1 so, this is the only extra point.

So, whatever we have got here, we have obtained the same result here.

So, we need 3 squarings from x , we need to compute x square, then x^4 , then x^8 and we need 2 multiplications because there are 3 terms to be multiplied, 2 multiplications; so, 3 squarings and 2 multiplications.

So, the point is the number of squarings will always be the same.

If this x to the power n , let us say if I write x to the power n , if n is a k bit number then I will always require k minus 1 squarings that is fixed, but number of multiplication will be equal to how many 1's are there in these k bits.

So, the total time will depend on the how many multiplications are there; you see the number of squaring is fixed; number of multiplication is variable.

So, if I measure the time, I can get a very fair idea about how many multiplications are carried out.

So, I can know how many 1's are there in this power n .

Continued

So, I can get lot of information about the key.

Now, this is a pseudo code in C like language that implements that same algorithm; because the numbers are very large number these are not integers, I am using a special data type called big number called Bignum.

If you look at this algorithm, this is a C program, it exactly computes whatever was mentioned here.

Now, the point is that suppose I am computing this kind of x to the power n for some value of n and during this calculation; well, here I am, the time is all right, but if I look at the total time you see this pictorially I am showing something.

So, whenever there is a 1 in the bit you need a squaring also multiplication.

So, you need more time; there is another 1 you need more time, another 1 you need more time, but when there is a 0 then you need only a squaring, no multiplication.

So, your time is less.

So, you can say, if there are k number of bits, so, there will be k number of 1's squaring, t square plus, how many 1's are that I do not know; if m number of 1s are there in this n , then m into t multiplication.

Continued

So, if I measure this time the first part is constant, second part I can directly get the value of m ; I can know how many multiplications.

And if I observe some kind of current waveform on the oscilloscope I can see a waveform like this, I shall see.

I shall again come back to it later; you can directly see that which are 0's and which are 1's; if you observe the way from visually on the oscilloscope directly also, you can see and by measuring time also you can directly get how many 1's are there in the power, ok.

So, the algorithm basically works like this; you are checking the bits one by one; if the bit is 1, you do both multiply and squaring; if the next bit is 0, you do only squaring, no multiplication; that is how the difference in the time is coming.

So, naturally the question arises if I want to stop anyone from doing this kind of an attack, if I can make these two symmetrical like, if I also add a dummy multiplication here so that both the branches of this if statement take same time, multiply, squaring, here also multiply, squaring, then the times will become same and this timing analysis cannot be mounted.

So, what I mean to say is that, if I modify this algorithm that same one and add a dummy multiplication here, this does not do anything just a dummy multiplication; I am just adding in between here, but what it results in is that, all the times now become same.

So, you cannot distinguish anything just by measuring the time.

So, a design will become resistant to timing analysis attack.

Key terms

Term	Meaning in this lecture
So, you are, I	so many, you are assuming that no one is knowing what you are watching, but the video cable that is connected to a TV let us say that is going and is getting connected to an antenna which is on your roof; someone outside your house can connect some kind of a probe on that cable and can capture that data that is flowing through that cable that is what I mean by data coupling; that you can see; that is data coupling, And that data if I connect to another TV, I can see exactly what you are watching; I can replicate that; if I amplify it suitably and I plug into another TV I can see what you have been watching inside, ok.
Power x , n So, what it actually	I am trying to compute x to the power n . is that, if the device as I have said that is carrying out the operation is available with me, it is in my hand; it is available for analysis, then I can take it in the lab.

Exam-oriented recap

- So, we continue with the discussion on hardware based attacks.
 - So, let us see, what is a side channel attack?.
 - See over the communication channel some communication is going on; someone has captured it and you are trying to decode it; but side channel attack is different.
 - Therefore, in future generation devices this kind of consideration has to be incorporated in a very big way and all security devices and systems must have this kind of consideration in place, fine.
 - So, side channel attack is important; because the main point is the developer of a secure product; suppose, I am developing some product related to security, ok.
 - So, the developer of the product has to defend the product against all possible attack paths; it can be software based, it can also be hardware based.
 - Then side channel attack, the point to notice that we are not saying that the cryptographic algorithms that are running inside the devices are bad or weak we are not saying that.
 - Similarly, faulty outputs, some of the outputs, you can inject some fault; these are called fault analysis attacks.
-

L48: Side Channel Attacks — Part II

Transcript: [48-side-channel-attacks-part-ii.md](#)

Video: <https://www.youtube.com/watch?v=UhEOC3RRBhw>

Week / theme: Week 8 — Passwords, phishing, Wi-Fi, DoS, hardware security

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- We continue with the discussion on Side Channel Attacks.
- And in this lecture we shall be talking about another kind of side channel, that is power analysis attack ok.
- In the previous lecture if you recall, we had talked about timing analysis attack.
- And in this lecture we shall be talking about another kind of side channel, that is power analysis attack ok.
- In this talk we shall be first talking about power analysis attack.

What this lecture teaches

Core concepts from the lecture

We continue with the discussion on Side Channel Attacks.

In the previous lecture if you recall, we had talked about timing analysis attack.

And in this lecture we shall be talking about another kind of side channel, that is power analysis attack ok.

So, this is the second part of the talk.

In this talk we shall be first talking about power analysis attack.

There are two types of power analysis attack that can be mounted: simple and differential.

And lastly you shall be talking about some of the countermeasures ok.

So, let us see what this attack is all about.

Continued

Now incidentally, this power analysis attack was also proposed by the same gentlemen Paul Kocher three years later after timing analysis attack was proposed in the year 1998.

Now the point is that this kind of an attack is much more effective as compared to timing analysis attack.

This is much more efficient and much more effective.

The idea is that in timing analysis attack we are measuring the time right.

Here we are trying to measure the power that is consumed by the device.

Suppose there is a battery operated device that is working, inside some cryptographic operation is going on; may be it's a smart card reader.

Let say somehow I am measuring how much current the device is drawing from the battery or from the power supply source.

If I can measure that; that will give you give me an information about how much power is being drawn by that device ok.

Continued

So, this kind of an analysis can yield information about the device is doing.

And just like timing analysis, here also we can extract the key confirmation.

Let us see this in a little more detail.

The attack setup will look something like this, here is our device ok.

This can be any kind of a device; this can be smart card reader; this can be an FPGA board, this can be a box which is computing something, anything.

But from outside some power supply connection must be there right; either from the mains or from battery.

So, the only thing you have to do, you have to have an access to that point from where the power is being drawn.

And if you can connect a very small resistance in series to that and if you can connect a probe across it, and if you use a storage oscilloscope to store the sample files, what is a storage oscilloscope?

Continued

Storage oscilloscope will read the values in excess of time.

And we are storing it in memory and will be displaying it the waveform on the screen.

Storage means it is also storing in memory, so that you can do offline processing on that data if you want ok.

This is the data acquisition or attack setup whatever you call.

This is in a slightly more detail where you see a storage oscilloscope here.

You see an actual smart card reader here, where small resistance is connected in series just as I said to the battery.

And there is a computer system, which controls this device smart card reader; usually the smart card reader is connected to a computer system ok.

And this storage oscilloscope will be capturing the data; storing it and they will be transferring that file to a computer system for offline processing.

Continued

This is how typically it works ok.

Now, an offline processing you can do using any language; for example, you can also do it in MATLAB if you want.

So, in this simple power analysis, we use the same power analysis setup that we showed; to visually analyze the waveform; observe the waveform.

And the attacker can directly get lot of information about what is going on inside.

Now, if the waveform is too complex then it can be captured, transferred to the computer and offline some processing can be done ok.

Now, in this process we can compute a lot of things like, square and multiply in RSA exponentiation or some features of other complex algorithms also.

And this is relatively easy to defend against and one thing you just recall in the previous lecture when you said that.

When you observe an waveform, we can directly see different places where you will see some variations in the waveform for modular exponentiation example.

Continued

And you can directly say that which are the 1 bits and which are the 0 bits in the key.

So, you see in timing analysis you are only able to estimate how many ones over there.

But here if you can visually see the waveform, you can exactly tell what was the key; which are the zeros and which are the ones; that is the big advantage.

So, conceptually speaking, the waveform can be something like this, where for 0; the waveform will be like something different and 1, it will be something different.

I am just showing it conceptually like this.

So, just by looking at the waveform, you can directly get this; suppose the key is 101011; you can directly say it will be like this, 01011; like this it is coming.

And if you introduce that dummy operation, which we talked about in case of timing analysis attack to make the two parts of the if statement symmetrical, then there will be no difference in the operation during zero and one bits.

Both will do square and multiply together.

Continued

So, they will appear to be all similar.

So, simple power analysis will not work.

So, simple power analysis will work, can give you the exact key when no counters measures have been implemented; that means, dummy operation has not been incorporated.

Then you can directly get the key, if you mount this kind of an attack.

But differential power analysis is much more sophisticated.

But also mathematically more complex; I am just trying to give you the basic concept, how it works.

Here we need to make multiple measurements.

In simple power analysis we are making only measurement and by visually inspecting, we are directly able to say the key; let us say for the example like modular exponentiation for RSA.

Continued

Here we make multiple measurements; we do some kind of a comparison of the different waveforms, we do subtraction.

And we try to see in that after subtraction whether you get some peak somewhere or not.

This peaks are coming from mathematical, there is mathematical foundation behind it.

So, I am not going into the mathematical details.

So, we are looking for peak by looking at the difference waveforms.

We are trying to estimate the key; what can be the bits of the key?

I am, by trial I am assuming it to be 0, to be 1 and making measurements; take difference waveform and see whether peak is coming.

If peak is coming, then my guess is correct; if peak is not coming, then my guess is wrong; the idea is something like this.

Continued

Pictorially it is like that, so I make many measurements.

And depending on the different selection bits I change the bits of the key.

And I again get multiple measurements; I take the difference.

And after difference, I get the differential power analysis curve.

Just pictorially I am showing it like this.

And this DPA curve as I had said, if you see, you see in some of the curve, you can distinctly see some peaks like here, which means here the correct key guess you have done.

So, these waveforms are being shown, this one is for a correct key guess and this for an incorrect key guess.

So, if the key guess is correct, then you will be getting a peak like this; if it is not correct, then you will not be getting any peak; wave form will be something like this ok.

Continued

So, the idea is very simple; you carry out a large number of such experiments; compute a lot of such traces; take different you see.

Even if there is, this kind of counter measures implemented, then also DPA is able to break it.

So, DPA requires much more stronger counter measures to stop it from detection.

So, it is much more sophisticated in that respect ok.

Now, let us talk about some of the countermeasures.

For timing analysis as I had said the countermeasure was relatively simple.

There was only one if statement; you try to make the two branches of the if statement symmetrical in terms of time.

In one of the branches there was a square and multiplication, other branch there was only a square.

Continued

So, we added a dummy multiplication to make them equal ok.

But in power analysis attack, particularly differential power analysis attack we have to have much more sophisticated countermeasures.

Because differential power analysis attack will not be you can say, even if you make the two branches symmetrical, still differential power analysis attack can identify those peaks; if the key guesses are correct ok.

So, the countermeasures that are proposed for differential power analysis, they are both hardware based or software based; you can do it in both ways; some of them I am just mentioning here.

For hardware based countermeasures, you see there are some logic design style; here I am talking about IC design; normally we design on IC chips using CMOS.

In CMOS also there are various design styles, dynamic; under dynamic also there are several types static.

So, you should use some kind of a design style, where power consumption will not differ much depending on what kind of operation is going on.

There are some logic design styles where data dependent leakages are less.

Continued

So, it is better to use those kinds of design styles.

And there is something called masking scheme; we talked about obfuscation in the first lecture in this series.

So, when you are storing some data we are trying hide.

Let say I want to store a number n ; I am not storing it as n .

Let us say I am taking it exclusive-OR with some other value k_i and I am storing this.

So, unless I know k_i , I cannot retrieve n that is the thing.

Or I can use some kind of noise generator; it will generate some random numbers, it will generate random power noise, random interrupts; these are some of the counter measures.

Similarly, for software based countermeasures, here you can introduce some redundant computations, then some randomization; you can mask the data; these random values are added or multiplied.

Key terms

Term	Meaning in this lecture
Storage	it is also storing in memory, so that you can do offline processing on that data if you want ok.

Exam-oriented recap

- We continue with the discussion on Side Channel Attacks.
- In the previous lecture if you recall, we had talked about timing analysis attack.
- And in this lecture we shall be talking about another kind of side channel, that is power analysis attack ok.
- In this talk we shall be first talking about power analysis attack.

- There are two types of power analysis attack that can be mounted: simple and differential.
 - So, let us see what this attack is all about.
 - Now incidentally, this power analysis attack was also proposed by the same gentlemen Paul Kocher three years later after the timing analysis attack was proposed in the year 1998.
 - Now the point is that this kind of an attack is much more effective as compared to timing analysis attack.
-

L49: Physical Unclonable Function

Transcript: [49-physical-unclonable-function.md](#)

Video: <https://www.youtube.com/watch?v=waPLRl43vVw>

Week / theme: Week 8 — Passwords, phishing, Wi-Fi, DoS, hardware security

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- In this lecture, we shall be talking about Physical Unclonable Function or PUF.
- Now, in this lecture we shall first be talking about the basic concepts of physical unclonable function, then some applications of PUF and how they can be implemented ok.
- We mentioned earlier that this physical unclonable function plays a big role in designing systems in terms of hardware such that it becomes secure.
- Means, in other words with respect to hardware security this physical unclonable function or PUF can be used to design secure systems in a relatively easier way.
- So, let us see what this PUF is actually all about.

What this lecture teaches

Core concepts from the lecture

In this lecture, we shall be talking about Physical Unclonable Function or PUF.

We mentioned earlier that this physical unclonable function plays a big role in designing systems in terms of hardware such that it becomes secure.

Means, in other words with respect to hardware security this physical unclonable function or PUF can be used to design secure systems in a relatively easier way.

So, let us see what this PUF is actually all about.

Now, in this lecture we shall first be talking about the basic concepts of physical unclonable function, then some applications of PUF and how they can be implemented ok.

Talking about what is a physical unclonable function; you can say it is some kind of a fingerprint of some device.

Now, how do you define a fingerprint?

Suppose, as a human being my fingerprint is something which is supposed to identify me; my fingerprint is supposed to be unique.

Continued

So, in the same way whenever I design some hardware circuit and IC chip, the idea is there must be something which should be unique to that IC chip.

It can be acting as a some kind of a fingerprint of that particular device.

So, PUF is something like that; the concept is that.

It is defined as the fingerprint of some kind of a device.

Suppose, I have this kind of a PUF and we define something called challenge response mechanism.

The way a PUF box is that suppose I can have a chip; I can have a chip and inside my chip the PUF can be sitting in between; this can be my PUF ok.

Now, the idea is that when we use a PUF, there is a concept of a challenge and response pair or challenge response mechanism that comes into the picture.

The idea is, suppose, I feed a challenge C; this is some data I feed as input; I call it as a challenge and I get an output which I call it as a response R.

Continued

This C and R is referred to as the challenge response pair ok.

So, this PUF defines a mapping between this challenge and this response and the idea is that this PUF is something for which the challenge response pair is unique.

If I design another IC chip where may be the same kind of a PUF I am building, but for that PUF the challenge response properties will be different.

So, challenge response will be something like a fingerprint of that particular device ok.

So, this is something which you define as unclonable, it cannot be copied, it cannot be cloned and instance specific.

It is specific to that particular chip.

The way it is implemented this depends on manufacturing process variations.

When multiple chips are fabricated there will always be small variations here and there.

Continued

No two things can be exactly identical ok.

So, that process variations, device variations that is what is exploited in the design of this PUF ok.

Some of the desirable properties of PUF are mentioned here.

These are quite obvious.

First is it should be something which should not be too difficult to evaluate in terms of the challenges response.

Suppose, I give a challenge x , the response y should be easy to calculate, easy to compute ok.

It should be easy to evaluate.

Secondly, for a particular device, the challenge response property sho...

Secondly, for a particular device, the challenge response property should be unique.

The value of PUF x for a particular x will contain some information about the identity of the, physical identity; that means, if I talk about a particular chip there is a PUF here, whatever x I feed here, the PUF of x if I call it y .

So, whatever value I get y , this should uniquely identify this IC chip this should provide as the identity.

And, in the previous slide we have already mentioned there is a concept of unclonable; means given one PUF implement; that means, one chip, I have a PUF inside; if I have another copy of the same chip; there is also the same kind of a PUF, but the two PUFs will never be identical.

One PUF let us call it PUF, other PUF call it as PUF dash.

They will always be unequal means for some given challenge, if you compute the response for the first one, compute the response for the second one, they will not be equal.

So, it is hard to construct two PUFs which are not the same such that for the same value of x their response will be the same; their response will be different that is the idea.

And, it is a one way function that from y , from x you should get y , but given y you should not be able to get back x .

Continued

It is quite similar to hash function calculations, the reverse mapping should be difficult ok.

Let us take a simple example of an S-R latch.

I will just try to explain what this fabrication dependent or device dependent variations mean.

Well, if you recall for those of you know how an S-R flip flop works; this is a single bit storage which store 1 bit of information, ok.

There is one input “in” that same input is fed to this S and R let us say.

This S and R are two different inputs; let us assume that the same input value “in” is fed to both S and R.

Now, let us say I apply 1 to input.

If I apply a 1 here then the output of this NOT gates will be 0; this will be 0; these are NAND gates.

Continued

So, one input 0 means the outputs will be 1; both the outputs will be 1; both y and y prime will be 1 ok.

Now, let us say this in was 1; now I make it 0; I change it to 0.

So, at this point in time both y and y prime were 1 and 1.

So, as soon as I make it 0 this outputs of the NOT gates will both become 1, this will become 1; this will also become 1.

Now, here something happens; you see these are two gates.

Now, two gates are fabricated in the chip.

The two gates can never be exactly identical.

Suppose, this gate is a little faster; let us call it F; this gate is a little slower; let us call it S.

Continued

This gate faster means when this is 1, so both the inputs are 1 and 1, 1 and 1 NAND output is 0.

So, this output will be changing to 0 first, because this gate is faster.

This gate is slower, so, this output is still not 0.

So, this will become 0 first and this 0 will be fed back; 0 and 1 this will remain as 1; but if it were the other way round, then this would have become 0; this would have become 1.

So, this output y whether it will finally become 1 or 0, it depends on the relative delays of the two gates which you cannot predict beforehand.

So, here there is a source of randomness; it depends on fabrication ok.

This is the basic idea behind which this kind of PUF design we are trying to build, fine.

Now, from theory to practice usually these PUFs today the most of the research papers if you see, people have tried to build this PUFs around field programmable gate arrays or FPGAs.

Continued

Many security protocols and implementations are based on FPGAs and people have also implemented PUFs inside FPGAs.

Now, the advantage of FPGAs is obvious; you can create a design and burn it on a FPGA in your lab, in-house.

You can program it, you can change the design whenever you want.

But, you should need to implement carefully when the implementation of a PUF is required, ok.

See, for a particular implementation there may not be any non-determinism; like say you again look at that S-R flip flop, the same S and R; this kind of flip flop is there.

Suppose, in an FPGA implementation I design it in such a way that these two gates are placed in two different places in the chip; let us say one gate is placed here and one gate is placed here, and these two interconnecting lines, their lengths may not be same; one may be like this; one may be like this.

So, one interconnection will be longer which means its delay will be longer.

So, if this delay is longer, so that longer path can be the slower of the two; the other path will be faster.

Continued

So, it depends on the layout; the way you connect, place the two gates and connect them; that which gate effectively will be faster; which will be slower and whether the output finally in the example you took, whether it will be finally settling to 0 or to 1 right.

So, this depends; you will have to understand that.

Now, if you look at a chip; here I am looking at the FPGA chip.

So, these are the different grids.

Let us assume that the NAND gate that I was talking about; that NAND gate I can potentially place in any of the grids; I can place it here; I can place it here; I can place it here; let us say I can place it here; I can place it here; I can place it here, so many places.

Now, it depends where we are placing.

Depending on that some of them if I set the input to 1 and then to 0, just in the previous example, some of them will be settling down to 0; some of them will be settling down to 1.

So, accordingly what will be the final values of y's that will depend on how you are interconnecting them?

Continued

So, it does not depend on the circuit, but rather on how you are making the interconnection; where you are placing which gate.

So, in FPGA particularly here I am not fabricating anything; you are mapping a design into a programmable fabric.

So, where you are mapping, how are you interconnecting that will depend, that will determine what will be your final challenge/response pair of that PUF in terms of the S-R flip flop that we have just now talked about right.

So, the difference in the routing delays of these paths will determine that whether the flip flop output will be settling to 0 or 1.

So, and that will depend on which location you are placing the flip flop, the x, y coordinates right.

So, talking about the advantages of PUF, if you talk about PUF as a basic building block, you are using to design secure hardware, there are broadly two things - it reduces the cost of secure implementation; it also increases the security.

Now, here I am showing two things.

If there were no PUF, then trusted party embeds and tests secret keys in a secure non volatile memory; this is the typical thing which is done.

Continued

Inside the chip some secret value is stored in a non-volatile memory that is used for encryption/decryption.

There is some kind of a flash memory, EEPROM and adversary on attacker can physically extract through side channel attacks.

But, if you have a PUF, then some properties of the device that can be used to generate the secret key and the key will never be stored anywhere; the key will never come out of the IC chip.

Depending on intrinsic property of some delays inside the chip, the key value will be automatically generated.

And, the key is automatically deleted after is used.

It is not stored anywhere.

This is the advantage.

There is another application of PUF where you want to identify; like I have fabricated or I have designed the device and someone has made a clone or a copy of my device; I want to find out which is the original and which is the copy.

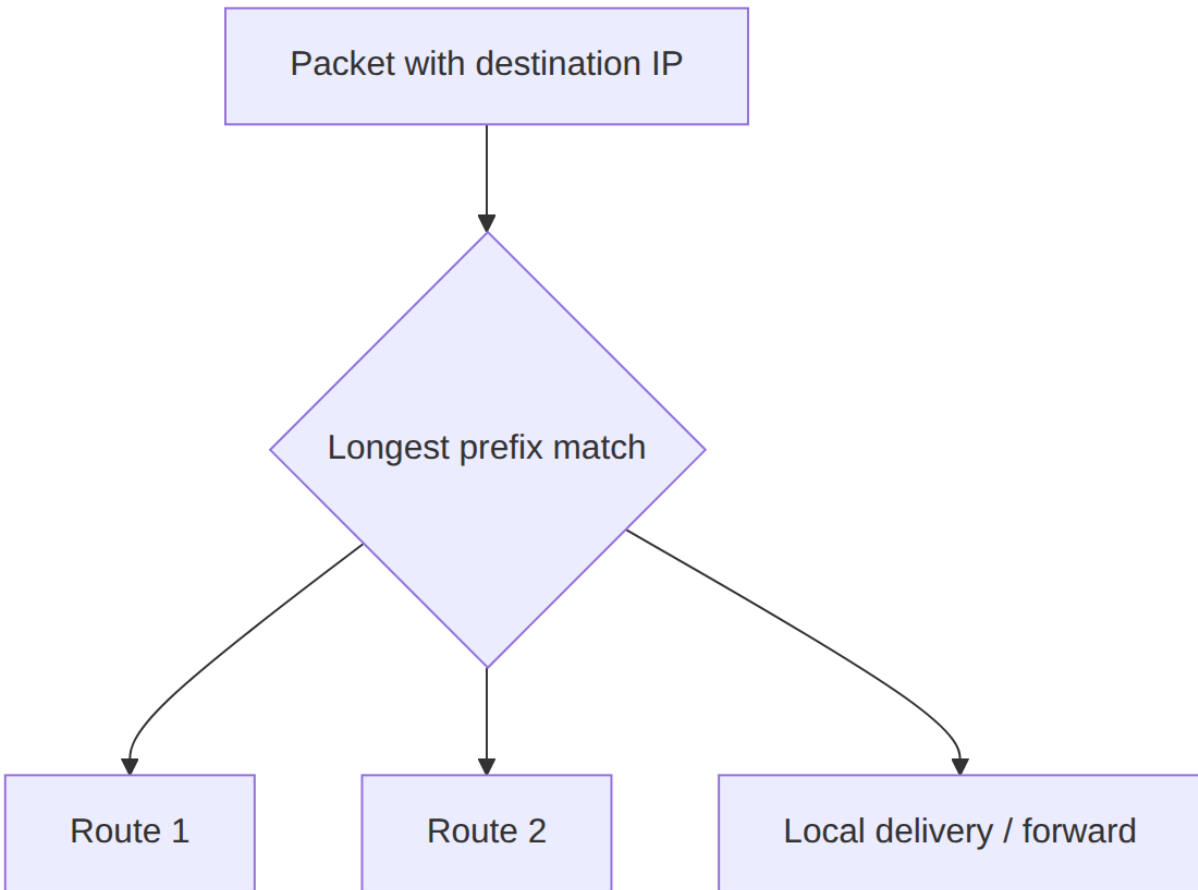


Figure 6: Architecture diagram

Key terms

Term	Meaning in this lecture
They will always be unequal	for some given challenge, if you compute the response for the first one, compute the response for the second one, they will not be equal.
So, one input 0	the outputs will be 1; both the outputs will be 1; both y and y prime will be 1 ok.
This gate faster	when this is 1, so both the inputs are 1 and 1, 1 and 1 NAND output is 0.
So, one interconnection will be longer which	its delay will be longer.
This	arbiter PUF.
This	ring oscillator.

Exam-oriented recap

- Means, in other words with respect to hardware security this physical unclonable function or PUF can be used to design secure systems in a relatively easier way.
- So, in the same way whenever I design some hardware circuit and IC chip, the idea is there must be something which should be unique to that IC chip.
- When multiple chips are fabricated there will always be small variations here and there.
- They will always be unequal means for some given challenge, if you compute the response for the first one, compute the response for the second one, they will not be equal.
- The two gates can never be exactly identical.
- Many security protocols and implementations are based on FPGAs and people have also implemented PUFs inside FPGAs.
- Now, the advantage of FPGAs is obvious; you can create a design and burn it on a FPGA in your lab, in-house.
- You can program it, you can change the design whenever you want.

L50: Hardware Trojan

Transcript: [50-hardware-trojan.md](#)

Video: <https://www.youtube.com/watch?v=Fu3eWo-w5YE>

Week / theme: Week 8 — Passwords, phishing, Wi-Fi, DoS, hardware security

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- In this lecture, we shall be talking about Hardware Trojans.

- So, in this lecture, we shall first be talking about hardware Trojan what it is; the different types of Trojans and how we can possibly detect the presence of Trojans?.
- Now, we shall, we have mentioned in the previous lecture, that a hardware Trojan is something, a piece of hardware which is hiding inside another larger piece of hardware.
- It wakes up at some unpredictable times and does something which is again unpredictable with respect to the user of the system ok.
- So, let us see, what this hardware Trojan is really like and why it acts like, how it does.

What this lecture teaches

Core concepts from the lecture

In this lecture, we shall be talking about Hardware Trojans.

Now, we shall, we have mentioned in the previous lecture, that a hardware Trojan is something, a piece of hardware which is hiding inside another larger piece of hardware.

It wakes up at some unpredictable times and does something which is again unpredictable with respect to the user of the system ok.

So, let us see, what this hardware Trojan is really like and why it acts like, how it does.

So, in this lecture, we shall first be talking about hardware Trojan what it is; the different types of Trojans and how we can possibly detect the presence of Trojans?

So, hardware Trojans I mentioned before, that the name has come from the ancient story in Greece, where inside a horse a large wooden horse, some warriors were hiding; they entered a castle and they finally conquered the castle.

So, this is the picture of that.

So, in terms of hardware security, hardware Trojan is essentially some malicious modification of this circuit inside an IC chip.

Continued

The circuit has been modified without the possible knowledge of the person who had designed the chip.

This is malicious and this modification can happen during design or it can happen during fabrication also.

When you are designing the circuit, you may not be aware that someone has modified your design and when you are finally sending a designed for fabrication to a fab, there also when your chip is getting fabricated, you really do not know what is happening there; may be something extra is also getting fabricated inside that chip ok.

So, hardware Trojan, HT sometimes you call in short, is characterized by two things: physical representation, how it behaves, how it looks like and what is its action; how it actually shows up; what are the effects of that hardware Trojan?

And there is also something which we called payload; whenever the hardware Trojan wakes up, the action that takes place is referred to as payload.

So, payload is the entire activity that happens when the Trojan gets triggered, ok.

So, these are just some pictures.

So, as I had said, the diagram on the left.

Continued

Suppose this was my original circuit.

So, some inputs are coming, some outputs are obtained, outputs are getting.

Now, someone has designed a malicious hardware; this is my Trojan.

Trojan consists of a trigger; it decides when the Trojan will wake up and the payload will decide what will happen when the Trojan wakes up.

And this hardware Trojan gets inserted somewhere in the original circuit; that means, it goes inside the circuit like this.

To the user, user does not know that something like this has happened; still the inputs are applied; outputs are, outputs are obtained.

Most of the time the circuit behaves normally; but sometimes the circuit may behave unpredictably, erratically, maliciously, whatever you say, whenever the Trojan gets triggered.

This is the basic idea.

Continued

Now, there are several reasons why a Trojan might get inserted in a design, in a chip?

Well here are few points which have been listed.

So, maybe one or more than one of these points are responsible for that.

First is prevalence of IP based design.

See IP stands for intellectual property, not the IP protocol, the network protocol.

In this context for hardware, here IP stands for intellectual property core; when you design an IC chip, the chip can contain many building blocks; these are called IP cores.

Now a days, the chips have become so complex that these IP cores we do not design all ourselves.

Many of the cores we take from some other place; like a processor core you can take from somebody and mpeg decoder core I can take from someone else and so on.

Continued

So, I trust that person from where I am getting it.

I have not designed that.

So, if that person is giving me a core with a Trojan inside, I have no control over it.

I have trusted that person and inserted that core in my design, ok.

And, secondly when you design some circuit, we use some CAD tools, some software.

The software is also not designed by us.

We buy it from Cadence, Synopsis, Mentor Graphics, some company, large companies.

So, we really do not know what that company, the person who wrote that tool, did to the software.

Continued

So, in good faith we are using that software to design a circuit.

But whatever circuit is getting designed, how do I have a guarantee that it is the same circuit I am wanting to design or something else has also gone in to it, some malicious piece of code.

Fabless manufacturing model, we do not manufacture ourselves; we give it to someone else to manufacture.

So, there itself something wrong might happen.

Like here, these are related, outsourcing of manufacturing to offshore fabs.

So, we are slowly losing control over design and manufacture.

We are not designing the whole thing.

We are certainly not manufacturing, most of the time someone else is manufacturing.

Continued

So, there lot of parties involved.

If one of the parties involved are malicious, then there is a possibility of a Trojan getting inserted in your design.

So, there are potentially untrusted parties which are getting involved in the whole process.

So, let us have a overall picture here.

This is a very simplified diagram that how typically we design an IC chip.

As I had said that we have the intellectual property or IP cores, the designs we take from other two places.

We have the computed design tools that you use.

Some standard cells, standard cell library also we can take from some other places.

Continued

And we can have some models based on which you are designing, some circuit models.

Based on this, we are creating our design.

There is a process; we go through the steps of the design; we finally generate something called a gds to file, which is our fab interface; we can send it to the fab for fabrication.

There the masks are manufactured and the finally, the chip is fabricated.

Now you see, these yellow boxes are not totally trusted and red boxes are definitely untrusted, because they are typically offshore and when these things are happening, we are not there at all.

We are very far away.

So, when the things come back, when the chip comes back to us, when you are doing this package, testing, again we are using a tester from a third party; that is also not totally trustable.

So, you see there are so many untrusted parties involved here.

Continued

So, it is very surprising that, whatever design still works right, but well, we have to trust people and we have to work in a group in collaborative way, right.

That is how things work.

But, these are some of the reasons why we may have Trojans getting inserted in our design.

That is what I wanted to say.

So, essentially hardware Trojans are, as I had said, malicious modifications to the design, can take place prior to manufacturing, during design, pre or post manufacture; even after manufacturing when the chips are getting assembled, there also a small chip can be inserted in the wafer side by side that may be an extra thing getting inserted.

So, you will not know; it can happen at many places.

These are inserted by some adversary who is certainly very intelligent; because no ABC can do this thing; only an expert can do this kind of malicious insertion, malicious modification.

And as you can understand that the amount of hardware overhead that is required to insert a Trojan is not much, very small.

Continued

So, maybe of your entire chip less than 0.1 percent extra hardware is required to insert that Trojan.

Maybe even less; the 0.1 is a very large number.

This is stealthy; stealthy means it is hiding; you cannot see it; very difficult to detect.

The IC can manufacture, can malfunction in field sometime; you do not know when.

The time is also unpredictable, ok.

Result is that, result can be, this can be potentially disastrous; you can have some circuits which you have put on board as spacecraft.

The spacecraft has gone to space and during its space maneuver, something wrong happens due to the Trojan.

So, the effect can be catastrophic, right.

Continued

There can be loss of a lot of property and even human life.

Now, the point is that, how realistic are hardware Trojans?

All these, what have been talking about is theory and good stories; but do Trojans really exist?

Well, there is no concrete proof that someone has actually inserted Trojan and has actually done it; but there are cases where, people suspect that something might have happened; but not 100 percent sure that it was due to a Trojan, ok.

You see tempering masks in the fab; something happening in the fab during fabrication is extremely unlikely; not impossible, because it is very very sophisticated and very expensive to do that, ok.

Reverse engineering of an IC to understand what your original design is, then I insert a new circuit that can take a long time.

So, that is also not so easy for someone to do reverse engineer and then insert a Trojan.

But there are number of suspected military and commercial cases where people suspect that something has happened.

Continued

Like, I am giving one example; I am not taking any names, suppose you have purchased some equipment from some other place; let say guns; guns are very common things which people buy from other places, other countries.

When you buy, you test they were fine; but at time of war, you try to fire the guns and you see that, suddenly you see that the guns are getting locked; they are not firing.

So, we suspect that there may be some Trojan inside; someone is possibly controlling your guns remotely from other places, maybe through satellite; something is getting controlled; you do not know, ok.

So, reverse engineering of ICs is also quite common in many industries like IBM, many others also.

So, talking about Trojans, there are many different types of Trojans.

Combinational, sequential; this is one category.

There is another way of classifying Trojans; that what is the trigger condition; what is the payload; that is another way to look at Trojans.

And another way to look at, what is the physical attribute?

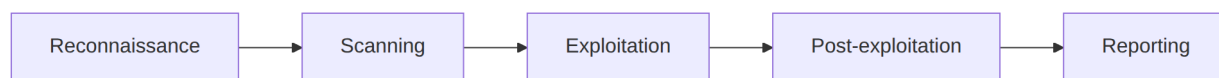


Figure 7: Architecture diagram

Key terms

Term	Meaning in this lecture
This is stealthy; stealthy	it is hiding; you cannot see it; very difficult to detect.
So, another type let see; this	combinational Trojan; this is a combinational circuit.
So, that	asynchronous, because you cannot exactly correlate with clock.

Exam-oriented recap

- So, in terms of hardware security, hardware Trojan is essentially some malicious modification of this circuit inside an IC chip.
- And there is also something which we called payload; whenever the hardware Trojan wakes up, the action that takes place is referred to as payload.
- Most of the time the circuit behaves normally; but sometimes the circuit may behave unpredictably, erratically, maliciously, whatever you say, whenever the Trojan gets triggered.
- Whenever these, both signal p and q are 1 and 1, then only one clock will come.
- Whenever the temperature reaches some level, then only the Trojan will get triggered.
- Whenever the temperature reaches let us say 60 degrees, then only some triggering will happen.
- They can forcibly pull a line to 1 or pull down to 0, whenever something happens, ok.
- Like, we already talked about side channel attacks.
